Cheetah
by BocTrust

SOLUTION ARCHITECTURE · AWS

Cloud Platform & DevOps Architecture

Target-state design for hosting the Cheetah backend services and admin dashboard on AWS: request path, network and security boundaries, delivery pipeline, resilience and cost.



ECS Fargate · ARM | CloudFront + WAF | RDS PostgreSQL | GitHub Actions · OIDC | 2 Availability Zones

REGION	VERSION	DATE	CLASSIFICATION
eu-west-1 (Ireland)	1.0 · Draft for review	October 2026	Confidential

01 · OVERVIEW

Executive Summary

Customers and staff reach the platform through a single CDN and firewall. The API runs as containers in private subnets beside one managed PostgreSQL database; the admin dashboard is served as static files. Releases are built in CI, apply the database migration first, and roll out gradually with automatic rollback.

5
Node.js services on ECS Fargate (ARM)

1
Public entry point — CloudFront + WAF

2 AZ
Multi-AZ VPC; Multi-AZ RDS in production

0
Long-lived AWS keys in repos or CI

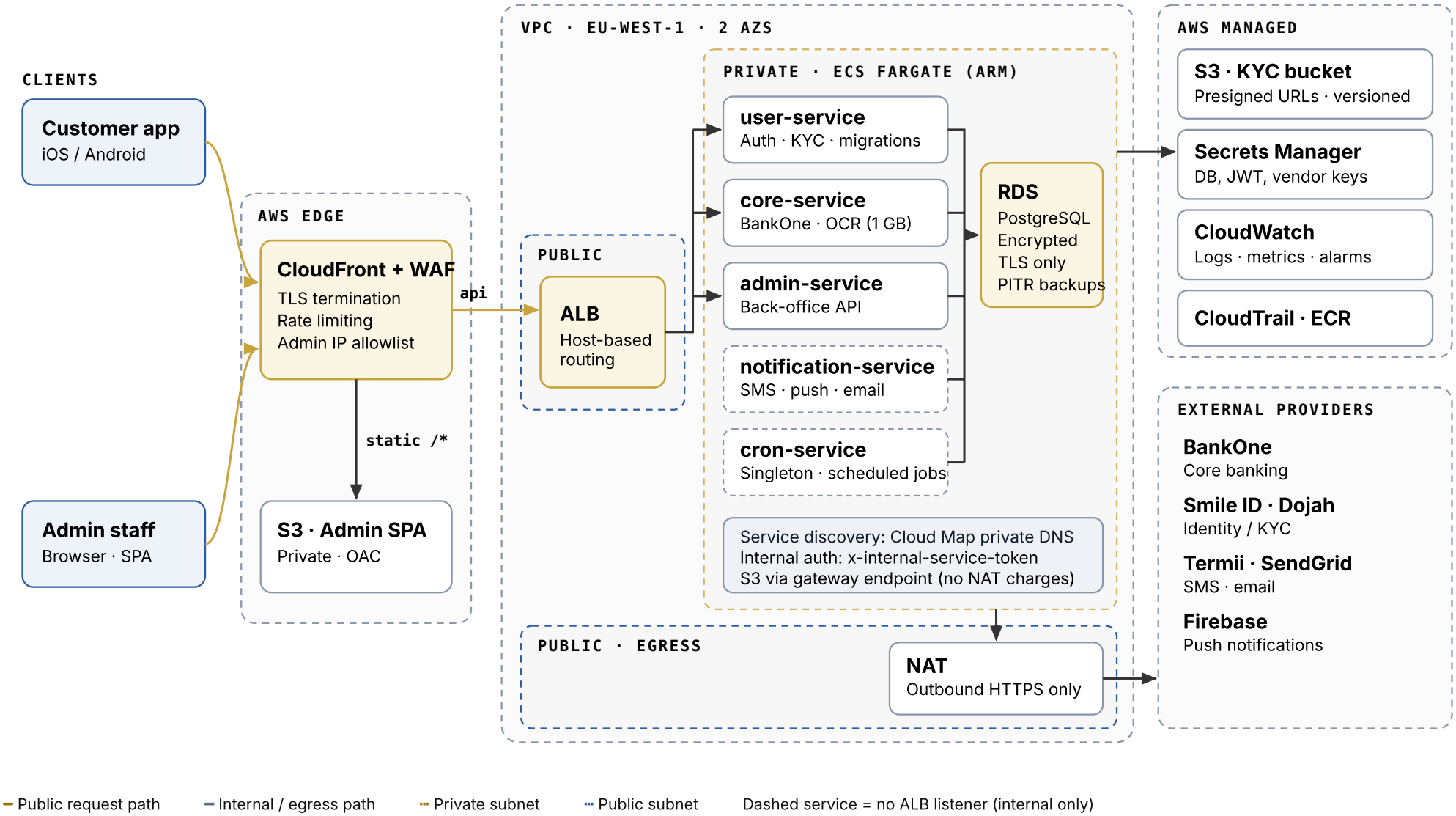
Design principles

- **Single edge.** All traffic enters through CloudFront and WAF; only the ALB is internet-facing.
- **Private by default.** Containers and database run in private subnets with no public IPs.
- **Least privilege.** IAM task roles, Secrets Manager, security groups scoped per service.
- **Immutable releases.** Images built once in CI, tagged by commit, promoted unchanged.
- **Cost-aware.** ARM compute, one shared ALB, NAT instance in non-production.

Scope

Backend	user, core, admin, notification and cron services
Frontend	Admin dashboard (Vite SPA)
Clients	Cheetah iOS / Android app, staff browsers
Integrations	BankOne, Smile ID, Dojah, Termii, SendGrid, Firebase
Environments	Staging and production

Target-State Architecture



03 · TRAFFIC FLOW

Request Lifecycle

How customer and staff traffic moves from the client to the services and back.

Customer app → API

1. **HTTPS to CloudFront**
   API hostnames resolve to CloudFront; TLS terminates at the edge.
2. **WAF inspection**
   Managed rule sets and per-IP rate limits drop malicious traffic before it reaches compute.
3. **Forward to ALB**
   ALB accepts traffic only from CloudFront (managed prefix list + origin secret header).
4. **Host-based routing**
   `user-api`, `core-api`, `admin-api` each map to one target group.
5. **Fargate task handles request**
   Private subnet, no public IP; reads RDS, secrets injected at start, S3 via presigned URLs.
6. **Vendor calls via NAT**
   BankOne, KYC, SMS, email and push leave through outbound-only egress.

Admin dashboard → admin-api

1. **SPA served from CloudFront**
   Files read from a private S3 bucket via Origin Access Control; no servers.
2. **Edge access control**
   WAF restricts the admin hostname to office / VPN IP ranges.
3. **API calls to admin-api**
   Same edge → ALB path as customer traffic; lands on admin-service.
4. **Application authentication**
   Dashboard login and role checks still apply behind the network controls.

> **Caching.** API paths are not cached at the edge (per-customer responses). Hashed static assets are cached for one year; only `index.html` is revalidated.

Component Selection & Rationale

Each component, its responsibility, and why it was chosen over a cheaper or simpler alternative.

COMPONENT	RESPONSIBILITY	RATIONALE
CloudFront + WAF	Single public entry; TLS, rate limiting, static hosting	Absorbs floods before they consume compute; admin SPA needs a CDN, so the API shares it.
Application Load Balancer	Host-based routing, health checks, cross-AZ distribution	Enables zero-downtime rolling deploys. One shared ALB keeps a large fixed cost to a single unit.
ECS Fargate (ARM)	One task definition per service; no hosts to patch	Graviton pricing beats x86 at equal size; removes the single-server failure point of today.
RDS PostgreSQL	Shared database, automated backups, point-in-time restore	Managed operations without a dedicated DBA. Multi-AZ enabled in production only.
S3 (KYC bucket)	KYC media and profile images	Block Public Access, SSE encryption, versioning; access only via presigned URLs.
Secrets Manager	DB credentials, JWT / encryption secrets, vendor keys	Keeps secrets out of images and repos; rotation without rebuilds.
NAT (egress)	Outbound access from private subnets to vendor APIs	NAT instance for staging (vs. ~$32/month + data for NAT Gateway); managed gateway for production.
ECR	Container registry	Scan-on-push for CVEs; lifecycle policy retains recent tags only.
CloudWatch + CloudTrail	Logs, metrics, alarms, API audit trail	Required controls for a regulated financial product; low cost with tiered retention.

Service Communication & Security Controls

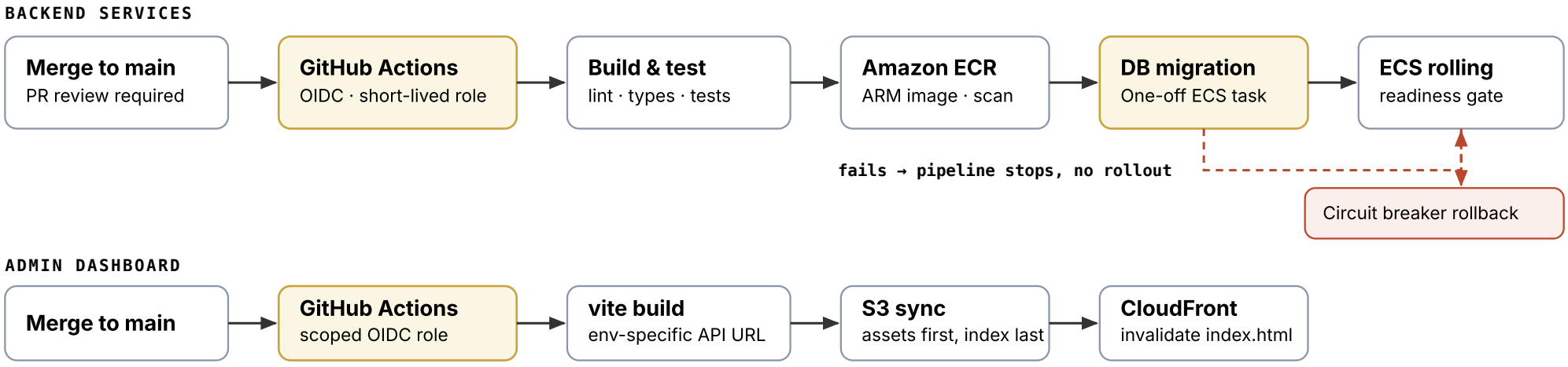
Services call each other over private DNS (Cloud Map) with a shared internal token. Security groups enforce the allowed paths below as a second layer.

SOURCE	DESTINATION	PURPOSE
ALB	user, core, admin	Public API. No listener for notification or cron.
user-service	core-service	Tier refresh, BankOne provisioning after KYC
cron-service	user, core	KYC retries, interest accrual, monthly credits
admin-service	notification, core	Broadcasts and admin reads
user, core, admin	RDS :5432	Shared database; no other source permitted
Private subnets	NAT → Internet	Outbound HTTPS to vendors only

Security controls

- ALB restricted to CloudFront origin; direct access refused.
- `/internal/*` returns 403 at the ALB.
- Swagger `/api/v1/docs` and `/health/metrics` blocked at the edge in production.
- IAM task roles replace static AWS keys for S3 access.
- Secrets injected from Secrets Manager at task start.
- RDS: private subnets, encryption at rest, TLS enforced.
- CloudTrail enabled for all management events.

CI/CD Pipeline



Keyless CI

GitHub Actions assumes an AWS role via OIDC. No access keys are stored in repositories or CI secrets. The admin pipeline uses a separate role limited to its bucket and distribution.

Migration before rollout

user-service owns the shared schema. Its new image runs `migrate:user:up` as a one-off Fargate task; a failure halts the pipeline while the current version keeps serving.

Gated rollout

New tasks must pass `/health/readiness` before old tasks drain. The ECS deployment circuit breaker restores the previous task definition automatically.

Failure Modes & Recovery

Expected system behaviour for each deployment failure scenario.

SCENARIO	OUTCOME
Build or tests fail	Nothing is pushed; production untouched.
Database migration fails	Pipeline stops before any service restarts; current version keeps serving; SQL error in task logs.
New version fails health checks	ECS circuit breaker rolls back to the previous task definition automatically.
Migration breaks running code key risk	Old and new tasks briefly share the new schema. Mitigated by expand/contract migrations: add first, remove in a later release.
Defective release reaches production	Redeploy the previous image tag from ECR; apply the down migration where schema changed.
Availability Zone outage	ALB and tasks span two AZs; production RDS fails over to its Multi-AZ standby.

Cron singleton. cron-service credits savings interest nightly, so a second copy would double-credit. It runs as exactly one task with a stop-then-start deployment (no overlap), and jobs are designed to be idempotent.

Current State vs Target State

Key changes from today's single-server deployment.

AREA	CURRENT	TARGET
Hosting	One EC2 instance; PM2 runs all five services	ECS Fargate (ARM), one task definition per service
Deployment	SSH on port 22, `git reset --hard`, build on server	CI-built images, OIDC role, rolling deploy with rollback
Secrets	`.env` files on server; AWS keys in env vars	Secrets Manager at task start; IAM task roles
Database	To be confirmed	RDS PostgreSQL, private, encrypted, PITR backups
Edge	Server exposed directly	CloudFront + WAF; only the ALB is public
Admin app	Not yet deployed	S3 + CloudFront on a separate hostname

Platform adaptations required

- Build once in the image; run `node dist/index.js` (remove rebuild-on-start).
- Host-based ALB routing — all three APIs share `/api/v1`.
- Larger task size for core-service (Tesseract OCR).
- Prefixed config (`BOCTRUST_PROD_*`) set via task definitions.

Cost Estimate, Decisions & Go-Live Actions

Indicative monthly ranges, to be validated against current eu-west-1 pricing. ALB, RDS and WAF are the largest fixed items.

Monthly estimate

Staging (single-AZ DB, scheduled shutdown)

$60 – $90

Production (Multi-AZ DB, WAF, on-demand)

$200 – $300

Decisions required BocTrust

- Environment sequencing: staging and production together or phased
- Domain and DNS provider
- Current database location and size
- Current user volume
- IaC tooling: Terraform or CDK
- Mobile app support for per-service hostnames

Before go-live security

- Rotate the test account and remove committed `test-user-credentials.txt`
- Remove static AWS keys; rely on task roles
- Block `/internal/*`, Swagger and metrics at the edge
- Lock ALB ingress to CloudFront